MSM ACADEMY

SECTION 1

Information security and ISMS fundamentals



1.1 Information and information security
1.2 The information security management system
1.3 ISO/IEC 27001:2022 and related standards
1.4 Continual improvement and PDCA

MSM ACADEMY

SECTION 1 · LESSON 1.1

Information and information security

1.1

What we protect, and why

LESSON 1.1

Information as something to protect

Information and other associated assets

- Information in any form: databases, documents, paper, conversations, people’s knowledge
- Associated assets: systems, devices, networks, facilities and the people who use them
- Its value lies in what the organization and others rely on it for

LESSON 1.1

Confidentiality, integrity, availability

Property	Meaning in plain words	Example
Confidentiality	Not made available or disclosed to unauthorized people, entities or processes	Patient records seen only by authorized staff
Integrity	Accurate and complete	A dosage that has not been altered
Availability	Accessible and usable on demand by authorized entities	Records available in the emergency room at night

LESSON 1.1

More than IT

Security is a business matter

- People: awareness, competence, behaviour
- Processes and physical measures: procedures, access to buildings, secure disposal
- Technology: one part of the answer, not the whole of it

LESSON 1.1

Risk in one sentence

Why security is risk-based

- Not every piece of information needs the same protection
- Risk decides where protection is needed, and how much
- Section 6 teaches the method in full

Information security: two perspectives



Implementer's view

- Start from the information and what people rely on it for
- Protect people, process, physical and technology together
- Let risk decide the level of protection



Auditor's view

- Ask what information is in scope and why it matters
- Look beyond technical controls
- Expect protection proportionate to risk

LESSON 1.1 · RECAP

Lesson 1.1 recap

- Information in any form, with associated assets
- Information security preserves confidentiality, integrity and availability
- People, process, physical and technology, not IT alone
- Risk decides where protection is needed

Check your understanding

A payroll file is changed by mistake and employees are paid the wrong amounts. No one outside saw it. Which property was lost?

A. Confidentiality

B. Integrity

C. Availability

D. None, because nothing was disclosed

Check your understanding

A payroll file is changed by mistake and employees are paid the wrong amounts. No one outside saw it. Which property was lost?

A. Confidentiality

B. Integrity

C. Availability

D. None, because nothing was disclosed

Answer: B

Integrity is the property of accuracy and completeness. The file was altered, so integrity was lost, even though nothing was disclosed.

MSM ACADEMY

SECTION 1 · LESSON 1.2

The information security management system

1.2

What an ISMS is and does

LESSON 1.2

What a management system is

Elements that work together

- Interrelated or interacting elements of an organization
- Used to set policies, objectives and processes to achieve those objectives
- Includes structure, roles, planning, operation, evaluation and improvement

LESSON 1.2

What an ISMS does

Preservation through risk management

- Preserves confidentiality, integrity and availability by applying a risk management process
- Gives confidence to interested parties that risks are adequately managed
- Part of, and integrated with, the organization’s processes and management structure

LESSON 1.2

Sized and integrated

One size does not fit all

- Scaled to the organization’s needs, size and structure
- Expected to change as the organization changes
- Shares processes with other management systems where it can

LESSON 1.2

Critical success factors

Factor	In practice
Aligned policy and objectives	Security activities serve business objectives
Visible management support	Commitment from all levels, especially top management
Risk-based understanding	Protection requirements come from risk management
Awareness and incident management	People know their obligations; incidents are handled well
Continuity and measurement	Business continuity; performance measured and fed back

ISMS: two perspectives

Implementer's view

- Build the ISMS into existing processes
- Size it to the organization
- Secure visible management support early

Auditor's view

- Look for integration, not a parallel system
- Judge suitability for this organization
- Test whether management support is visible

LESSON 1.2 · RECAP

Lesson 1.2 recap

- A management system: interrelated elements setting policies, objectives and processes
- The ISMS preserves CIA by applying risk management
- Integrated with the organization’s processes, sized to its needs
- Success factors are mostly about people and management

Check your understanding

A company buys an “ISMS software platform” and declares its ISMS complete. What is the main misunderstanding?

A Software cannot store ISMS records

B An ISMS must be paper-based

C An ISMS is the organization’s interrelated policies, processes, roles and decisions, not a tool

D Only certified companies may use ISMS software

Check your understanding

A company buys an “ISMS software platform” and declares its ISMS complete. What is the main misunderstanding?

A. Software cannot store ISMS records

B. An ISMS must be paper-based

C. An ISMS is the organization’s interrelated policies, processes, roles and decisions, not a tool

D. Only certified companies may use ISMS software

Answer: C

A management system is a set of interrelated organizational elements: policies, objectives, processes, roles and decisions. A tool can support it but is not the system.

MSM ACADEMY

SECTION 1 · LESSON 1.3

ISO/IEC 27001:2022 and related standards

1.3

The standard, its structure, and this course

LESSON 1.3

A requirements standard

What “shall” means

- Clauses 4–10 state requirements an organization must meet to conform
- Annex A lists information security controls used as a reference in risk treatment
- Certification by a third party is the organization’s choice, not a requirement

LESSON 1.3

The harmonized structure and Amendment 1

Shared clauses, and a 2024 addition

- Clauses 4–10 follow the harmonized structure shared with other management system standards
- 4.1: determine whether climate change is a relevant issue
- 4.2: note that relevant interested parties can have climate-change requirements

LESSON 1.3

The standards this course uses

Standard	Where you meet it
ISO/IEC 27001:2022 + Amd 1:2024, with ISO/IEC 27000:2018 terms	Section 2, and throughout
ISO/IEC 27002:2022 (Annex A control guidance)	Section 3
ISO/IEC 27005:2022 (information security risk management)	Section 6
ISO 19011:2026 with ISO/IEC 27007:2020 (auditing)	Section 8
ISO/IEC 17021-1:2015 (certification bodies)	Section 9

LESSON 1.3

How the course is organized

Part	Sections
Foundations and requirements	1 Fundamentals · 2 Clauses · 3 Annex A
Implementer	4 Methodology · 5 Gap analysis · 6 Risk and SoA · 7 Documented information
Auditor	8 Auditing the ISMS · 9 The certification process
Simulations	10 Lead Implementer · 11 Lead Auditor
Completion	12 Certificate · 13 Final assessment

The standard: two perspectives

Implementer's view

- Treat Clauses 4–10 as non-negotiable
- Use Annex A through risk treatment
- Decide on certification as a business choice

Auditor's view

- Audit against requirements, not preferences
- Know which document a requirement comes from
- Respect the organization’s choices within the requirements

LESSON 1.3 · RECAP

Lesson 1.3 recap

- Clauses 4–10 are requirements; Annex A is a control reference
- Harmonized structure; Amd 1:2024 adds climate change to 4.1 and 4.2
- Five groups of standards, each with its section
- Implementer, auditor and simulation parts

Check your understanding

A manager says: “We are excluding Clause 9.2 because we are too small for internal audits.” What is the correct response?

A Clauses 4–10 are requirements and cannot be excluded; internal audit can be scaled

B Small organizations may exclude any clause

C Clause 9.2 is optional unless seeking certification

D Only Annex A controls are mandatory

Check your understanding

A manager says: “We are excluding Clause 9.2 because we are too small for internal audits.” What is the correct response?

- **A** **Clauses 4–10 are requirements and cannot be excluded; internal audit can be scaled**
- **B** Small organizations may exclude any clause
- **C** Clause 9.2 is optional unless seeking certification
- **D** Only Annex A controls are mandatory

Answer: A

Requirements in Clauses 4–10 cannot be excluded. Internal audit can be scaled to a small organization, but not omitted.

MSM ACADEMY

SECTION 1 · LESSON 1.4

Continual improvement and PDCA

1.4

A requirement, and a teaching model

LESSON 1.4

Continual improvement in ISO/IEC 27001

What the standard requires

- 10.1: continually improve the suitability, adequacy and effectiveness of the ISMS
- Inputs: monitoring and evaluation results, internal audits, management review
- Mechanisms: corrective action, changes decided by management, updated risk treatment

PDCA: a teaching model

1	**Plan**	Decide what to achieve and how
2	**Do**	Carry out what was planned
3	**Check**	Measure and evaluate the results
4	**Act**	Adjust and improve
5	**Note**	Teaching model, not an ISO/IEC 27001:2022 requirement

LESSON 1.4

Common misconceptions

Misconception	Reality
“PDCA is required by ISO/IEC 27001”	It is a teaching model; Clause 10.1 requires continual improvement
“Certification guarantees security”	It confirms a working system, not the absence of incidents
“The ISMS is an IT project”	It covers people, processes, physical and technology
“More documents means better security”	The standard requires a short list; the rest is a choice

Improvement: two perspectives

Implementer's view

- Plan how improvement actually happens
- Use audit, review and corrective action as inputs
- Use PDCA freely as an explanation, not a requirement

Auditor's view

- Audit continual improvement against 10.1
- Look for evidence of change, not a diagram
- Never raise a finding for not using PDCA

LESSON 1.4 · RECAP

Lesson 1.4 recap

- 10.1: continually improve suitability, adequacy and effectiveness
- Monitoring, audit, review and corrective action support improvement
- PDCA: a teaching model, not a requirement
- Four misconceptions to unlearn

Check your understanding

An auditor proposes a nonconformity because the organization’s ISMS manual does not mention the PDCA cycle. What is the correct view?

A Correct: PDCA is a core ISO/IEC 27001:2022 requirement

B Correct, but only for certified organizations

C It should be raised as an observation instead

D Not justified: PDCA is not required; audit continual improvement against 10.1

Check your understanding

An auditor proposes a nonconformity because the organization’s ISMS manual does not mention the PDCA cycle. What is the correct view?

A. Correct: PDCA is a core ISO/IEC 27001:2022 requirement

B. Correct, but only for certified organizations

C. It should be raised as an observation instead

D. **Not justified: PDCA is not required; audit continual improvement against 10.1**

Answer: D

ISO/IEC 27001:2022 does not prescribe PDCA. The auditor should audit continual improvement against Clause 10.1, using evidence of real improvement.

SECTION 1 · SUMMARY

Fundamentals in one view

- Information security preserves confidentiality, integrity and availability
- An ISMS does it by applying risk management, integrated in the organization
- ISO/IEC 27001:2022: requirements in Clauses 4–10, Annex A controls
- Continual improvement is required; PDCA is a teaching model

MSM ACADEMY

SECTION 1 COMPLETE

Next: Section 2

ISO/IEC 27001:2022 Clauses 1–10

